Vulnerability Scoring
The main scoring systems being considered are CVSS, EPSS, and CISA KEV.

- CVSS (Common Vulnerability Scoring System): Provides a standard severity score from 0–10 based on the technical characteristics of a vulnerability. It is useful as a baseline for comparing findings across scanners.
- EPSS (Exploit Prediction Scoring System): Estimates the probability that a vulnerability will be exploited in the wild within the next 30 days. This can provide an indication of real-world exploitation likelihood.

Source: Google

Feature	CVSS	EPSS
Core Purpose	Measures technical **severity** and impact.	Predicts the **probability** of exploitation.
Time Horizon	Static (rarely changes after initial analysis).	Dynamic (updates daily based on threat intel).
Score Range	0.0 to 10.0 (Low to Critical).	0.0 to 1.0 (0% to 100% chance in next 30 days).
Focus Area	System traits (access vector, privileges needed).	Real-world threat landscape (malware, scans, dark web).
Governing Body	FIRST (Forum of Incident Response and Security Teams).	FIRST (Forum of Incident Response and Security Teams).

**** If we want detailed/specific scorings- EPSS, if we want much more simplified, fixated scoring, CVSS.

The proposed approach is to investigate how consistently each scanner provides these metrics and determine how findings without CVSS or equivalent scores can be mapped to a common scoring system. The final prioritisation score could combine technical severity, exploitation likelihood, and known exploitation status rather than relying on scanner severity alone.

Test Applications
The following deliberately vulnerable applications are being considered for testing:

Scanner	Test Applications
OWASP ZAP	OWASP Juice Shop, WebGoat, DVWA
Nikto	Metasploitable, DVWA
Burp Suite / Trivy	OWASP Juice Shop, Docker-based applications

Nessus	Metasploitable, DVWA
Nuclei / Acunetix	DVWA, OWASP Juice Shop, WebGoat

- OWASP Juice Shop: https://github.com/juice-shop/juice-shop
  An intentionally vulnerable web application that can be used to generate security findings from web vulnerability scanners such as OWASP ZAP and Burp Suite.
- DVWA: https://github.com/digininja/DVWA
  A deliberately vulnerable web application containing common vulnerabilities. It provides a controlled environment for testing and comparing scanner results.
- OWASP WebGoat: https://github.com/WebGoat/WebGoat
  An intentionally insecure application designed for learning web application security. It provides additional vulnerabilities that can be used when evaluating scanner findings.
- Metasploitable3: https://github.com/rapid7/metasploitable3
  A deliberately vulnerable virtual machine containing vulnerable services and applications. It can be used for testing vulnerability scanners such as Nessus and Nikto.

By next week:

- [ ] **Research 2 Prioritisation algorithms**
- [ ] Try ZAP with DVWA